

第一讲 概述

一、信息安全概述

1、信息技术发展

信息化已渗透到社会的方方面面。

2、信息安全现状

(1) 病毒、黑客攻击的泛滥

➤数量规模大、智能程度高（技术含量）、组织方式多样化（个人、组织和集团等）……

➤危害程度严重

(2) 信息安全成为国家安全的重要内容

➤国家领导层的意识

➤信息化建设的经验、伊战的教训……

(3) 关键技术受制于人

➤CPU、OS……

➤专利、标准……

(4) 行业市场重点突出

➤随着 WTO 保护期临近结束，金融、政府、电信等重点行业在机构改革和业务创新的同时，IT 系统建设和整合不断深入，这为安全产品提供了广阔的市场空间，这三个行业是安全产品最大的市场，同时政府行业和电信行业近两年都将保持 35% 以上的快速增长；而能源、流通等行业的安全需求增长态势迅猛

(5) 市场竞争激烈，安全服务和产品创新成为厂商竞争焦点

- 竞争激烈，强强联合
- 安全服务市场成为安全厂商竞争的焦点。
- 产品创新主要表现在集成式产品。

3、信息安全威胁

(1) 信息安全威胁的表现：

- 网络协议的弱点
- 网络操作系统的漏洞
- 应用系统设计的漏洞
- 网络系统设计的缺陷
- 恶意攻击
- 来自合法用户的攻击
- 互联网的开放性
- 物理安全
- 管理安全

(2) 威胁的根源

- 信息系统的复杂性：
 - 系统软硬件缺陷，网络协议的缺陷
- 信息系统的开放性：
 - 系统开放：计算机及计算机通信系统是根据行业标准规定的接口建立起来的。
 - 标准开放：网络运行的各层协议是开放的，并且标准的制定也是开放的。

➤ 业务开放：用户可以根据需要开发新的业务。

4、信息安全含义

(1) 信息安全的六个方面：

→ 保密性 (Confidentiality)：信息不泄漏给非授权的用户、实体或者过程的特性

→ 完整性 (Integrity)：数据未经授权不能进行改变的特性，即信息在存储或传输过程中保持不被修改、不被破坏和丢失的特性。

→ 可用性 (Availability)：可被授权实体访问并按需求使用的特性，即当需要时应能存取所需的信息。

→ 真实性：内容的真实性

→ 可核查性：对信息的传播及内容具有控制能力，访问控制即属于可控性。

→ 可靠性：系统可靠性

(2) 信息安全特性

→ 攻防特性：攻防技术交替改进

→ 相对性：信息安全总是相对的，够用就行

→ 配角特性：信息安全总是陪衬角色，不能为了安全而安全，安全的应用是先导

→ 动态性：信息安全是持续过程

(3) 信息安全范围（存在 IT 应用的任何场景）

→ 管理与技术

→ 密码、网络攻防、信息隐藏

→单机、服务器、数据库、应用系统

→灾难恢复、应急响应、日常管理

→……

二、信息安全的困境

1、信息安全的需求

用户花费了很大的代价来解决信息安全风险，希望能够：保护业务不会被黑客破坏；限制责任和义务，满足法规和标准；避免对企业的品牌和信誉造成破坏。

2、主要的困难

然而在事实上，很多企业每年都花了数百万的资金在安全上，但是效果并不如意，信息安全问题越来越多。

3、软件安全的越来越受到重视

软件安全问题正日益成为信息安全问题的焦点。

超过 70%的安全漏洞出现在应用层而不是网络层。而且不只发生在操作系统或者 web 浏览器，而发生在各种应用程序中-特别是关键的业务系统中。

三、问题的原因和根源

1、软件问题的原因

(1) Connectivity（互联性）

- 终端设备的互联给了攻击者有更多的机会
- 攻击者利用系统弱点不再需要进行物理访问
- 平台设计缺陷

→不支持特定的安全功能，例如 SSL、认证授权机制等

→典型问题：无线蹭网卡

(2) Extensibility (扩展性)

●目前很多软件技术都支持扩展技术

→通过脚本、控件、组件、applet 等形式

→在 J2EE、.NET 技术里中比较常见

●优点在于可以很方便的加载以及扩展新的功能与组件

●问题在于扩展的功能与组件不可控，会带来未知的安全风险

(3) Complexity (复杂性)

软件系统代码增长速度惊人。

系统越复杂，Bug 越难避免，质量越难保证，可能发生的安全风险越多。

2、黑客攻击方式的进化

3、传统技术的不足

(1) 新的需求与传统安全技术的不足

●用户认证

→ 主机认证

➤ NTKM

➤ Kerberos

➤ .net Passport

→ 证书认证

➤ X.509

→ 网络认证

➤ Radius

➤ Diameter

➤ IKE

→ HTTP 协议只有较弱的认证技术

➤ 基本认证 rfc2617

➤ 表单认证

● 访问控制

→ Firewall

→ 针对网络的访问控制技术无法适用于 WEB

● 攻击监控

→ IDS/IPS

→ 无法监控 SSL/TLS 等机密应用

● 监控用户状态

→ 可以监控 TCP 连接

→ Session/cookie 机制的不足

● 阻止已知攻击

→ IPS

→ 应用层威胁很难被阻断

(2) 主要原因

● 传统网络安全技术只能对网络层进行防护

● 无法分辨与正常应用数据混杂在一起的攻击

→XSS

→SQL 注入

→未校验参数

→etc.

4、传统安全教育的不足

(1) 传统的安全思想

用防火墙来定义系统的“边界”，把软件与外界隔离
过分依赖加密技术

- SSL

- IPSec

当产品要发布的时候才去 Review 产品

- 以补丁（patch）的方式进行修复

允许新技术使用：

- 如果是新的,肯定有问题.

- 直到这种技术成熟了,才使用.

- 想尽一切办法去否定使用新技术的想法

(2) 传统的安全模式

- 保护“边界”

- 网络安全

- 安全负责的人是 IT/MIS/CISSP 等部门

- 被动式

(3) 新的安全模式

- 构建安全的系统
- 设计安全的软件
- 软件开发人员和设计人员对安全负责
- 主动式

5、软件安全的根源问题

软件安全的问题是软件自身的缺陷问题，主要在软件设计和软件实现的过程中产生，具体表现在软件设计的架构问题和实现上的错误。

- 开发软件—造房子
- 实现上的错误-软件代码错误—墙的问题
- 架构问题- 软件架构风险—梁的问题
- 在软件安全问题上，架构上的风险往往比实现上的分析更重要，更难理解。

四、主要解决途径-软件安全

1、概念

- 为了安全目的设计、开发、测试软件的过程。
- 其通过在软件自身中确定和清除安全问题来达到计算机安全的目的。

2、软件安全主要涉及的领域

● 策略与管理

- 教育与培训
- 标准与规范

● 需求与设计

→ 威胁建模

→ 安全需求

→ 防御设计

● 确认与评估

→ 架构审查

→ 代码审查

→ 安全测试

● 部署与实施

→ 弱点管理

→ 基础加固